

Python source / manifest
file · directory · multi-file package



Input validation & sanitisation
size limits · NUL stripping · type checks



Orchestrator — analyze()
content-hash cache · @resilient self-healing · health monitor



detection engines run behind circuit breakers (a failing engine degrades, never crashes)

Sink-aware AST scan
receiver-aware sinks · gating

Taint pattern matcher
probabilistic / chained / stego

Classic OWASP/CWE
SQLi · cmd inj · deser · TLS

Obfuscation channel
Shannon entropy + Higuchi FD

Symbolic reachability
Z3 · sound counter model

Secrets scanner
provider + import correlation

Dependency audit
typosquat · slopsquat

Quantum-inspired risk
state-vector · Von Neumann H



Two-axis scoring — severity × confidence
sink-aware confidence · symbolic bump · CWE + CVSS mapping



Dedup + context down-grade
fingerprint dedup · test/example files → Low



SARIF 2.1.0
CWE taxonomy · fingerprints

JSON report
flat · CI-consumable

CLI · Web UI
exit codes · attack narrative